ZeroPW 제품 정의

작성일: 2026-09-12 · 현행 제품 기준 · 기획·문서: Astra

1. 어떤 제품인가

ZeroPW는 에이전트에게 비밀값을 주지 않고 CLI·API를 사용하게 하는 개인용 클라우드 금고다. 서비스와 자격증명을 한 번 연결하면, 에이전트는 작업별 등록 없이 지원하는 CLI·API를 사용한다. 인증은 ZeroPW가 대신 처리하며 에이전트와 실행 코드에는 원본 키를 주지 않는다.

핵심 기능은 환경변수·API 키·비밀번호의 암호화 보관, 프로젝트별 관리, API 인증 중계, SSH 서명 위임, 접근 권한·만료·회수·사용 기록이다. 제품과 개발 하네스 모두 클라우드에서 운영한다. 첫 버전은 본인 한 명의 CLI·API 사용에 집중한다.

이 문서는 작업별 사전등록을 요구했던 이전 제안을 대체한다. 현재는 제품 정의 단계다. 아래 기능과 보안 기준은 구현 요구사항이며, 제품이 배포되었거나 개별 CLI의 호환성이 검증되었다는 뜻은 아니다.

2. 사용 흐름

1. 사용자가 별도 관리 화면에서 비밀값을 저장하고 프로젝트·환경에 연결한다. 서비스 대상, 자격증명, 허용 권한과 만료를 설정한다.
2. 에이전트는 사용할 연결을 선택하고 지원하는 CLI 명령이나 API 요청을 실행한다. 명령·하위 명령·API 작업을 하나씩 등록할 필요가 없다.
3. 에이전트 네이티브 도구가 통신 경로와 비밀이 아닌 설정을 준비한다. HTTP 요청은 인증 중계기로 보내고, SSH 클라이언트는 서명 서비스에 인증 서명을 요청한다.
4. 중계기 또는 서명기가 권한을 확인하고 인증을 처리한다. 에이전트는 업무 결과를 받으며 원본 자격증명은 받지 않는다.
5. 같은 연결의 허용 범위 안에서는 다른 명령도 계속 사용할 수 있다. 대상이나 권한 범위를 넓힐 때 연결 정책을 변경한다. 사용자는 사용 기록을 보고 권한을 회수할 수 있다.

예를 들어 하나의 코드 호스팅 서비스 연결에서 목록 조회와 이슈 생성처럼 서로 다른 API 요청을 쓸 수 있어야 한다. 이는 목표 UX의 예시이며 특정 서비스나 CLI의 지원 완료를 의미하지 않는다. 서비스별 프로토콜 통합은 제품이 제공하고, 사용자가 작업 카탈로그를 작성하게 하지 않는다.

3. 비밀 보관과 비밀 사용의 차이

금고는 환경변수·API 키·비밀번호·SSH 개인키를 암호화해 보관한다. 이 중 에이전트가 사용할 수 있는 인증 방식은 원본 값을 클라이언트에 주지 않고 중계하거나 서명할 수 있는 방식이다.

클라이언트의 환경변수에는 서비스 주소, 비밀이 아닌 설정, 불투명한 연결 참조만 둔다. 원본 비밀이 필요한 임의 프로그램을 그대로 실행하면서 그 프로그램이 값을 읽지 못하게 할 수는 없다. 해당 방식은 미지원으로 표시하며 실제 값을 환경변수·명령 인자·파일·credential helper 결과에 넣는 호환 경로는 제공하지 않는다.

원본 키를 보유할 수 있는 곳은 신뢰하는 금고·인증 중계기·서명기다. 인증 방식에 따라 외부 대상 서비스도 자격증명을 받는다. 이 제품은 이 신뢰 영역의 침해까지 막는 영지식 시스템을 약속하지 않는다. 에이전트가 허용된 권한을 악용하는 문제는 별도의 권한 제한과 회수로 다룬다.

업무에 필요한 텍스트와 API 응답은 에이전트에 전달한다. 결과를 성공 여부나 고정된 열거값으로만 제한하지 않는다. 인증 정보가 응답·오류·로그에 반사되는 경로는 별도로 차단한다. 업무 데이터는 에이전트와 모델 제공자에게 전달될 수 있으므로 모든 데이터의 비공개를 보장하는 제품은 아니다. 출력 마스킹은 보조 수단이며 원본 키를 클라이언트에 주지 않는 구조를 대신하지 않는다.

4. 첫 버전의 기능

기능	제품 요구사항
암호화 금고	환경변수·API 키·비밀번호·SSH 개인키 보관과 버전 관리. 관리형 비밀 저장소와 KMS 사용을 기본 설계로 한다.
프로젝트·환경 관리	프로젝트별 dev·staging·prod 연결과 권한을 구분한다.
서비스 연결	서비스·자격증명·대상·권한을 연결 단위로 설정한다. 사용자가 작업마다 등록하지 않는다.
API 인증 중계	지원하는 HTTP 인증을 신뢰하는 중계기에서 처리한다. 에이전트는 원본 키 없이 요청과 업무 결과를 다룬다.
SSH 서명 위임	지원하는 SSH 클라이언트에 인증 서명을 제공한다. 개인키 내보내기 없이 인증하며 첫 버전의 핵심 기능에 포함한다.
에이전트 네이티브 도구	연결 조회·선택, CLI 실행, API 요청, 상태 확인과 취소를 제공한다. 비밀값 조회 도구는 제공하지 않는다.
권한·만료·회수	호출 주체·연결·대상·권한·기간·사용량을 제한한다. 개별 권한 회수와 전체 실행 정지를 제공한다.
사용 기록·알림	누가 어떤 연결과 대상을 사용했는지 값 없이 기록한다. 비정상 사용과 실패를 알린다.
교체·복구	자격증명 수동 교체, 암호화 백업, 사용자 복구 절차를 제공한다. 공급자별 자동 교체는 후속 범위다.

브라우저 자동완성, TOTP·패스키, 카드 정보, 가족·팀 공유, 기업 SSO·SCIM, 멀티클라우드 운영은 첫 버전 범위 밖이다.

ZeroPW 자체의 KMS·관리·감사·백업·복구·결제·DNS 권한과 개발 하네스의 모델 호출·관리 키는 에이전트 업무용 연결에 넣지 않는다. 이 부트스트랩 권한은 별도 신뢰 영역에서 관리한다.

5. 지원 범위와 판정 기준

지원 후보	지원에 필요한 조건	조건을 만족하지 못하면
HTTP API·CLI	인증을 중계기에 위임할 수 있고 프록시·base URL·TLS 경로, 대상 검증, 응답 처리를 통제할 수 있어야 한다.	해당 API 또는 CLI를 미지원으로 표시한다.
SSH CLI	SSH agent 프로토콜 연동과 서버·목적지에 대한 인증 요청의 결합을 검증할 수 있어야 한다.	개인키 파일만 받거나 목적지를 검증할 수 없으면 미지원이다.
비밀번호 기반 인증	HTTP Basic 등 지원 프로토콜의 인증을 중계기가 대신 처리할 수 있어야 한다.	DB 등 다른 프로토콜은 전용 중계 검증 전까지 미지원이다.
평문 비밀로 계산하는 프로그램	프로그램 자체가 원본 값을 요구하므로 이 제품의 비밀 비전달 조건을 충족하지 못한다.	보관은 가능하지만 해당 실행 방식은 미지원이다.

지원 판정에는 정상 요청 성공뿐 아니라 하나의 연결로 서로 다른 명령을 등록 없이 실행하는지, 원본 키 추출이 차단되는지, 응답·오류·스트림·로그에 인증 정보가 유출되지 않는지, 권한 회수가 적용되는지 확인하는 시험을 포함한다. 조건이 맞지 않으면 명시적으로 실패해야 하며 평문 주입으로 우회하지 않는다.

특정 CLI, 서비스, 클라우드 제공자·리전·예산은 아직 확정하지 않았다. 실제 사용할 서비스 후보로 프로토타입을 검증한 뒤 지원 목록을 정한다. 모든 CLI가 수정 없이 동작한다고 약속하지 않는다.

6. 1Password에서 참고하는 부분

1Password의 환경변수 관리와 비밀 참조는 금고·연결 UX의 참고 대상이다. 다만 op run은 실제 비밀을 자식 프로세스의 환경변수에 넣으므로 ZeroPW의 실행 보안 모델로 그대로 사용하지 않는다. 출력 마스킹이 자식 프로세스의 값 접근을 막는 것은 아니다. [S1, S2]

1Password SSH agent의 개인키 비반출과 서명 제공 방식은 SSH 인증의 참고 대상이다. 관리용 MCP 도구와, 외부 MCP 서버를 감싸서 그 서버의 환경에 비밀을 넣는 방식은 구분한다. MCP를 쓴다는 사실만으로 실행 코드에서 비밀이 숨겨지지는 않는다. [S3, S4]

Envoy의 credential injector는 중계기에서 HTTP 자격증명을 넣는 구현 참고 사례다. 이 기능 하나가 사용자 권한, 목적지 제한, 응답 유출 방지 또는 모든 CLI 호환성을 해결하지는 않는다. 이 보호와 검증은 ZeroPW가 별도로 설계한다. [S5]

공식 자료 확인일: 2026-09-12

- [S1] 1Password Environments: https://www.1password.dev/environments
- [S2] 1Password CLI — op run: https://www.1password.dev/cli/reference/commands/run
- [S3] 1Password SSH agent security: https://www.1password.dev/ssh/agent/security
- [S4] 1Password — Secure AI access: https://www.1password.dev/get-started/secure-ai-access
- [S5] Envoy credential injector: https://www.envoyproxy.io/docs/envoy/latest/configuration/http/http_filters/credential_injector_filter

ZeroPW 인증 중계와 보안 경계

작성일: 2026-09-12 · 현행 설계 · 구현 전 요구사항

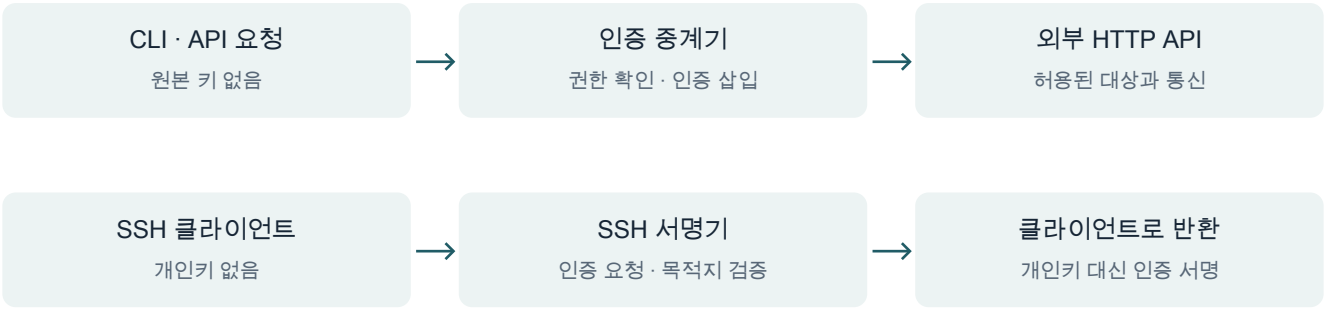
1. 보호할 경계

에이전트, CLI, 에이전트가 작성한 코드, 작업 파일과 도구 응답에는 원본 비밀을 제공하지 않는다. 비밀을 보유하는 금고·인증 중계기·서명기는 별도의 신뢰 영역에 둔다. 인증 중계기는 에이전트가 보낸 코드를 실행하지 않는다.

클라우드 실행 환경은 신원, 파일·프로세스 접근, 네트워크와 관리 권한을 분리해야 한다. 같은 호스트에서 프로세스만 둘로 나누고 디버깅·볼륨·관리 권한을 공유하는 구성을 격리로 인정하지 않는다. 비밀은 KMS 기반 암호화와 최소 권한으로 보호하며 신뢰 서비스 사이의 통신도 인증한다.

에이전트가 받는 제한된 사용 권한과 금고의 원본 자격증명은 다르다. 에이전트는 허용된 사용 권한을 행사하거나 유출할 수 있다. 따라서 짧은 만료, 대상과 권한 제한, 사용량 제한, 회수와 감사가 필요하다. 신뢰 영역 침해나 이미 허용한 행위의 피해까지 원본 비밀 비전달로 해결되는 것은 아니다.

2. 인증 경로



금고의 원본 키는 신뢰하는 인증 중계기·서명기에서만 사용

HTTP 업무 응답은 인증 정보 유출을 통제한 뒤 CLI·에이전트에 반환

SSH 세션은 클라이언트와 서버가 통신 · 서명기는 명령을 실행하지 않음

HTTP 요청에서는 중계기가 연결 정책을 확인하고, 허용된 대상에 보내는 요청에만 인증 정보를 넣는다. 응답에서는 인증 정보를 제거·차단한 뒤 업무 결과를 반환한다. 원본 키를 CLI에 돌려주지 않는다.

SSH에서는 클라이언트가 서버와 통신하고 서명기는 인증에 필요한 서명만 제공한다. SSH 세션의 명령 실행을 서명기가 대리하는 구조가 아니다. 서명은 검증된 SSH 인증 요청과 목적지에 묶고, 임의 바이트 서명이나 다른 용도의 서명에 같은 키를 사용하게 하지 않는다.

3. 연결과 네이티브 도구 계약

도구 이름은 구현 시 조정할 수 있지만 다음 계약은 유지한다.

도구	입력과 결과
list_connections	호출 주체가 사용할 수 있는 연결 ID, 설명, 지원 방식과 권한만 반환한다. 비밀값과 다른 사용자의 연결은 노출하지 않는다.
exec	연결과 명령·인자를 받아 비밀이 없는 실행 환경에서 지원 CLI를 실행한다. 라우팅과 인증 위임을 설정하며 일반 업무 출력과 실행 상태를 반환한다.
request	연결 ID와 HTTP 메서드·상대 경로·요청 내용을 받는다. 허용 대상에서만 인증을 처리하고 업무 응답을 반환한다.
status / cancel	본인 권한에 속하는 실행의 상태를 확인하거나 취소한다. 비밀이나 인증 헤더를 반환하지 않는다.

어떤 도구도 원본 비밀의 조회·내보내기를 제공하지 않는다. 모든 호출은 신원과 연결 소유권을 확인한다. exec는 신뢰하는 중계기 안에서 사용자 코드를 실행하지 않으며, request는 임의 호스트로 자격증명을 전송하는 기능이 아니다.

실행 환경에 전달하는 연결용 토큰이나 핸들은 원본 키와 분리하고 호출 신원·연결·대상·기간·사용량에 제한을 둔다. 도구가 지원하지 않는 CLI 인증 방식을 만나면 미지원 오류를 반환한다. 비밀을 환경변수·파일·인자에 넣거나 credential helper로 반환하는 대체 경로는 없다.

4. 프로토콜별 통제와 호환성

경로	필수 통제
HTTP 라우팅	연결의 대상 호스트·포트·TLS 서버 신원을 검증한다. 임의 호스트, 개방형 CONNECT, 리다이렉트, DNS 변경을 통한 내부망·메타데이터 접근이나 인증 정보 전달을 막는다.
HTTP 인증	외부로 나가는 요청에만 자격증명을 삽입한다. 호출자가 인증 헤더나 연결 선택을 조작해 다른 비밀을 쓰거나 읽지 못하게 한다.
HTTP 응답	일반 업무 응답은 제공한다. 인증 헤더 반사, 자격증명 조회·발급, 디버그 경로와 인증 정보가 포함된 오류·스트림은 서비스 특성에 맞게 제한한다.
SSH 인증	SSH agent 프로토콜과 세션·목적지 결합을 검증한다. 검증할 수 없는 클라이언트는 미지원으로 처리한다. 개인키 내보내기, 범용 서명, agent forwarding은 기본 허용하지 않는다.
로그·추적·임시 파일	요청 인증값과 금고 값을 남기지 않는다. 디버깅·충돌 보고·프록시 추적·오류 로그도 같은 기준으로 통제한다.

HTTPS CONNECT 터널만으로 암호화된 요청의 인증 헤더를 바꿀 수는 없다. 중계 가능한 base URL, 안전한 TLS 종단 방식 또는 해당 CLI의 공식 인증 위임 경로를 검증해야 한다. 인증서 고정이나 로컬 평문 자격증명을 요구하는 CLI는 지원이 어려울 수 있다.

서비스별 지원 프로필은 인증 방식, 대상, 자격증명을 노출하는 경로, 응답 처리와 호환 클라이언트를 정의한다. 이는 제품 통합 코드의 책임이며 사용자가 명령이나 API 작업을 매번 등록하는 절차가 아니다. 허용 범위 안의 다양한 요청은 같은 연결을 사용한다.

단순 문자열 마스킹으로 변형·인코딩된 유출까지 보장하지 않는다. 인증 정보를 반사하는 서비스 기능과 경로를 사전에 확인하고, 안전하게 중계할 수 있는 범위를 지원 목록에 명시한다. 지원 범위에서 인증 정보가 출력될 수 있는 경로를 통제하지 못하면 해당 통합을 출시하지 않는다. 외부 응답 속 지시문은 데이터이며 정책 변경 권한으로 취급하지 않는다.

5. 권한·승인·회수

기본값은 거부다. 권한은 호출 주체, 프로젝트·환경, 연결, 대상, 허용 행위, 만료와 사용량에 결합한다. 사용자는 연결의 범위를 설정하며, 같은 범위 안의 명령을 하나씩 사전등록하거나 매번 승인하지 않는다. 필요한 경우 삭제·결제 등 위험 행위에 추가 확인을 둘 수 있다.

사용 권한은 연결, 자격증명 버전, 대상과 정책 버전에 묶는다. 변경 시 기존 권한을 재평가하고 더 넓은 권한을 자동 승계하지 않는다. 각 요청과 서명 직전에 최신 회수·만료 상태를 확인한다. 특정 요청의 승인이 필요할 때는 입력 digest와 서버가 해석한 실제 대상·행위를 결합해 승인 뒤 입력이 바뀌지 않게 한다.

통합 코드의 릴리스 승인은 사용자 연결 권한과 별개다. 검증한 코드와 배포 산출물의 digest를 묶는 절차가 사용자에게 매 명령을 등록시키거나 호환 업데이트마다 작업을 재등록시키는 이유가 되어서는 안 된다.

즉시 회수는 회수 상태가 반영된 뒤 새로운 인증 중계·서명을 거부하고 대기 실행을 취소하는 것을 뜻한다. 진행 중인 요청은 가능한 범위에서 취소한다. 이미 외부 서비스가 처리한 작업을 되돌리거나 이미 인증된 SSH 세션을 자동 종료한다는 뜻은 아니다. 세션 강제 종료에는 대상 서버의 통제가 별도로 필요하다. 전체 실행 정지와 이상 사용 알림도 제공한다.

호출 주체와 요청 ID에 입력 digest를 연결해 중복 요청을 구분한다. 쓰기 작업의 성공 여부가 불명확하면 무조건 재시도하지 않고 상태를 확인한다. 모든 외부 서비스에 대해 exactly-once 실행을 보장하지 않는다.

6. 비밀과 운영 권한의 생명주기

관리 화면의 사용자 인증은 에이전트 신원과 분리한다. 비밀 입력·조회 화면을 에이전트가 조작하는 브라우저 세션에 연결하지 않는다. CORS를 권한 검사로 대신하지 않으며, 환경변수 파일 가져오기는 데이터 파싱으로 처리하고 내용을 실행하지 않는다.

사용자의 단일 비밀 조회는 재인증과 감사 기록을 요구한다. 초기에는 일괄 평문 내보내기를 제공하지 않는다. 복구 수단은 독립적으로 관리하고 복구 시 기존 세션·권한을 회수한다. 모든 복구 수단과 복호화 권한을 잃어도 항상 복구할 수 있다고 약속하지 않는다.

교체는 새 버전 등록, 인증 확인, 연결 전환, 외부 공급자에서 이전 자격증명 폐기 순서로 진행한다. 금고에서 값을 삭제하는 것만으로 공급자의 키가 폐기되지는 않는다. 암호화 백업을 복원한 뒤에는 최신 회수 상태를 적용하기 전까지 실행을 열지 않는다.

감사 기록에는 호출 주체, 연결, 대상, 행위, 결과와 정책 버전을 남기고 원본 비밀·인증 헤더는 남기지 않는다. 에이전트는 감사 저장소를 직접 읽거나 수정·삭제할 수 없다. 중계기·서명기는 필요한 기록 추가 권한만 갖고, 사용자 조회는 별도 권한으로 제공한다. 필수 감사 기록에 실패하면 인증 실행도 거부한다.

에이전트와 개발 작업자는 KMS·금고 관리자, 정책 관리자, 배포·감사·복구·백업 권한을 획득할 수 없어야 한다. ZeroPW 자신의 기반 권한과 모델 호출 키를 업무용 연결에 넣는 자기 참조 구성을 금지한다.

7. 구현 수용 시험

검증할 행동	통과 기준
연결 한 번으로 다양한 명령 실행	같은 연결에서 서로 다른 CLI·API 작업이 개별 등록 없이 성공한다.
에이전트의 원본 키 추출 시도	환경·파일·디버깅·다른 프로세스 접근으로 원본 값이 나오지 않는다.
응답·오류·로그를 통한 유출 시도	헤더 반사, 리다이렉트, 변형·인코딩, 스트림과 추적 경로에서 인증 정보가 노출되지 않는다.
다른 연결·대상 사용 시도	연결 ID 교체, 대상 변조, SSH 목적지 위조와 세션 재사용이 정책을 우회하지 못한다.
SSH 키 오용 시도	키 내보내기, 범용 서명, 허용되지 않은 forwarding이 거부된다.
미지원 CLI 실행	명시적 미지원 오류가 나오며 원본 키 주입으로 전환되지 않는다.
권한 만료·회수·전체 정지	새로운 인증을 거부하고 대기 작업을 취소한다. 기존 세션에 대한 한계를 UI와 시험에 명시한다.
운영·복구 경계 우회 시도	작업자 권한으로 관리·KMS·백업·감사·하네스 키에 접근하거나 회수 상태를 복원으로 되돌리지 못한다.

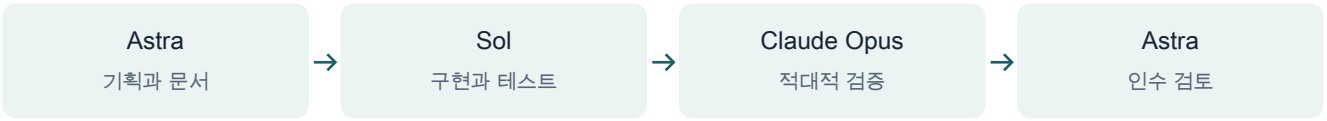
먼저 가짜 자격증명과 통제된 시험용 서버로 정상 동작과 공격 경로를 검증한다. 이 표는 앞으로 구현이 충족해야 할 기준이며, 현재 시험 완료나 보안 검증 통과를 뜻하지 않는다.

ZeroPW 클라우드 개발 하네스

작성일: 2026-09-12 · 운영 설계 · 구축 전

1. 역할과 작업 흐름

Astra가 제품 의도 정렬, PO, 사고·설계·문서와 인수 판단을 맡는다. Sol은 조사와 구현·시험을 수행한다. Claude Opus는 적대적 검증을 맡는다. 역할에 지정한 모델을 조용히 다른 모델로 대체하지 않는다. 클라우드 실행 환경에서 실제 이용 가능한 모델 ID·버전·권한은 하네스 구축 전에 확인하고 실행 기록에 남긴다.



검토 범위와 횟수는 요청에 따름 · 인수 뒤 보호된 릴리스 경로 사용

검증 기록은 해당 변경에 결합 · 개발 작업자와 운영 권한 분리

제품의 최상위 조건은 서비스 연결 뒤 작업별 사전등록 없이 지원 CLI·API를 쓰는 것과, 에이전트 및 실행 코드에 원본 키를 주지 않는 것이다. 편의를 위해 후자의 보호를 완화하는 결정을 하네스가 임의로 내리지 않는다.

검토 범위와 횟수는 사용자 요청을 따른다. 한 번의 검토 뒤 수정한 문서를 새 Opus 검증을 통과한 것처럼 표시하지 않는다. 구현 릴리스에는 해당 변경에 적용되는 검증 증거를 요구한다. 이전 설계에서 받은 PASS를 새 설계의 증거로 재사용하지 않는다.

2. 클라우드 구성

제품과 개발 하네스는 모두 클라우드에 둔다. 제품의 금고·인증 중계기·SSH 서명기, 제품을 사용하는 에이전트 CLI 실행 환경, 개발 작업자의 실행 환경은 서로 다른 권한 경계로 운영한다.

하네스는 오케스트레이터, 작업 큐, 모델 호출 계층, 임시 작업자, 산출물 저장소와 검증 증거 저장소로 구성한다. 모델 호출·관리 키는 신뢰하는 호출 계층이 보유하며 작업자 환경변수·이미지·프롬프트·도구 출력에 넣지 않는다. 개발 작업자에게 원본 모델 키를 넘겨야만 하는 실행기는 이 설계에 맞지 않으므로 그대로 사용하지 않는다.

생성한 코드와 CI는 가짜 키·시험용 서비스로 검증한다. 제품의 실제 비밀이나 운영 관리자 권한을 개발·리뷰 작업자에게 주지 않는다. 검증을 통과한 산출물만 별도 보호된 릴리스 경로로 배포한다. 작업자가 자신이 만든 코드를 곧바로 비밀 보유 서비스에 올릴 수 없어야 한다.

클라우드 제공자·리전·리소스 크기·예산·계정 권한은 실제 구축 전에 정한다. 이 문서는 하네스가 이미 클라우드에 구성되었다는 보고가 아니다.

3. 적대적 검증과 인수

Opus는 원본 키 접근, 인증 정보의 응답 유출, 대상·권한 우회, SSH 서명 오용, 프롬프트 인젝션, 회수·복구·감사 경계와 사용자 UX의 모순을 검토한다. 보고서에는 발견 사항의 원래 심각도, 위치, 재현 또는 근거, 수정 조건을 남긴다.

Astra는 Critical·High 발견 사항의 등급을 임의로 낮춰 릴리스를 통과시키지 않는다. 수정했다는 주장과 실제 해결 증거를 구분한다. 위험 수용은 해결 완료와 별도로 표시하며, 미해결 Critical·High가 있으면 자동 릴리스를 막는다. 추가 검증 여부와 범위도 명시한다.

검증 입력, 사용한 모델·버전, 결과 원문, 수정 대응, 산출물 digest를 함께 기록한다. 외부 문서·코드·도구 응답 속 지시는 검토 데이터이며 모델 역할이나 승인 정책을 바꾸지 못한다.

4. 사용자 권한과 코드 릴리스의 구분

사용자가 설정하는 단위는 연결·대상·권한·만료다. 사용자는 통합 코드를 작성하거나 작업마다 어댑터와 명령을 등록하지 않는다. 허용 범위 안에서 여러 CLI 명령과 API 요청을 반복 사용할 수 있어야 한다.

내부 구현에는 서비스별 프로토콜 통합 코드가 필요하다. 이 코드의 검증·버전·산출물 digest는 개발 릴리스의 관리 대상이다. 호환되는 코드 업데이트를 사용자 작업별 재등록이나 재승인과 결합하지 않는다.

연결의 비밀 버전, 대상, 권한 정책이 바뀌면 사용 권한을 재평가한다. 특정 위험 요청에 대한 승인이 필요하면 실제 대상과 입력에 결합한다. 개발 코드 승인과 사용자 행위 승인을 같은 증거로 대체하지 않는다.

5. 하네스 수용 기준

- 실제 실행한 Astra·Sol·Claude Opus 모델과 각 역할을 기록하고, 대체나 검증 누락을 숨기지 않는다.
- 제품과 개발 하네스 모두 클라우드에서 실행하며 작업자에게 제품 비밀과 모델 원본 키를 주지 않는다.
- 하나의 서비스 연결로 서로 다른 지원 CLI·API 작업을 개별 등록 없이 실행한다.
- API 인증 중계와 SSH 서명 위임을 각각 검증하고, 미지원 인증을 평문 주입으로 처리하지 않는다.
- 인증 정보의 응답·오류·로그 유출과 작업자의 운영 권한 획득 시도를 시험한다.
- 검증 증거와 배포할 산출물을 연결하고, 수정되지 않은 중대한 발견 사항은 자동 배포를 막는다.
- 중복 실행과 불명확한 쓰기 결과를 다루며, 실패 시 무조건 재시도하지 않는다.

이 기준은 향후 구축의 수용 조건이다. 이번 문서 수정과 PDF 생성은 구현 시험이나 새 보안 심사의 통과를 의미하지 않는다.

ZeroPW 문서 개정 반영 현황

작성일: 2026-09-12 · 의도 정렬 검토 후 수정

1. 이번 개정

2026-09-12의 Claude Opus 단일 검토 판정은 REVISE였다. 이번에는 사용자가 승인한 제품 설명에 맞춰 제품·보안·하네스 본문과 PDF를 수정했다. 앞부분의 교정 문구만 덧붙이는 대신 현행 설계를 본문 전체에 반영했다.

검토에서 지적한 차이	개정 내용
작업별 등록을 요구하던 UX	서비스 연결과 권한 설정 뒤 지원 CLI·API를 작업별 등록 없이 사용하도록 정의했다.
이전 실행 계약이 남아 있음	비밀 없는 CLI 실행, HTTP 인증 중계, SSH 서명 위임과 연결 기반 도구 계약을 작성했다.
SSH를 후속 기능으로 미룸	SSH 서명 위임을 첫 버전의 핵심 기능표와 보안·하네스 수용 조건에 포함했다.
지원 범위 판정 기준 부재	프로토콜별 조건과 검증 기준을 추가하고, 미지원이면 평문 주입 없이 실패하도록 명시했다.
사용자 승인과 어댑터 승인의 혼동	연결·권한·만료에 대한 사용자 결정과 통합 코드·산출물에 대한 릴리스 검증을 구분했다.
이전 내용을 담은 PDF	현행 문서로 다시 생성하고 인증 중계·서명 위임 구조와 개정일을 반영했다.

2. 검토 기록의 해석

이번 수정의 근거는 docs/reviews/2026-09-12-intent-alignment-once.md에 보존한 검토 1회다. 수정 후 새 Opus 검토를 수행하거나 PASS를 받은 것으로 표시하지 않는다. 문서 일치 여부와 PDF 출력 확인은 구현 보안 시험과 구분한다.

9월 11일 설계의 검토 기록과 기존 PASS는 당시 입력에만 적용된다. 변경 전 문서·PDF는 docs/archive/2026-09-12-before-auth-delegation에 보관했으며 현행 요구사항으로 사용하지 않는다.

3. 남은 구현 과제

실제로 사용할 서비스·CLI를 선정하고 HTTP 인증 위임과 SSH 목적지 검증의 호환성을 시험해야 한다. 클라우드 제공자·리전·예산과 하네스 모델 접근도 구축 전에 확정한다. 제품과 하네스는 아직 배포되지 않았으며 이 문서는 현재 합의한 제품 방향과 구현 수용 기준이다.